

Aim: Authentication attack using SETOOLKIT: To implement phishing using SE (Social engineering) Toolkit and understand its security concern

What is a Social Engineering Attack?

Social engineering is a form of psychological manipulation that **tricks** individuals into revealing **sensitive information**, bypassing security controls, or committing fraud. Unlike technical exploits that target system vulnerabilities, social engineering attacks **target the human element**, often the **weakest link** in any security chain.

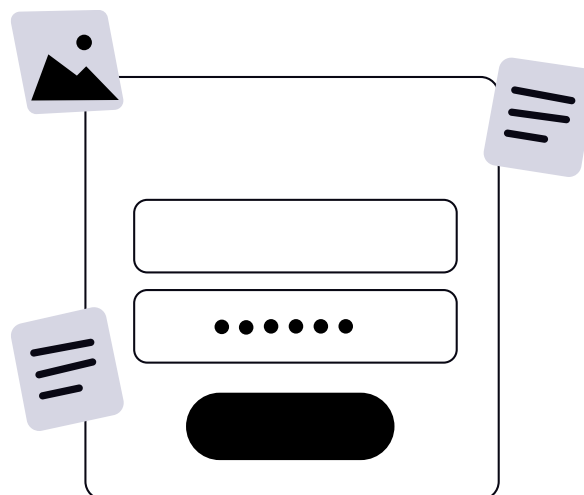
What is a Phishing Attack?

Phishing is a type of social engineering attack where an attacker **impersonates** a trusted entity, such as a bank, email provider, or corporate portal, to **deceive** victims into revealing sensitive information like usernames, passwords, or credit card details. It typically involves **sending fraudulent messages (via email, SMS, or social media)** that lure users to **fake** websites designed to **steal** their credentials. Unlike technical exploits that target system flaws, phishing targets **human trust** and **behavior**, making it one of the most **common** and **effective ways** to **breach** security.



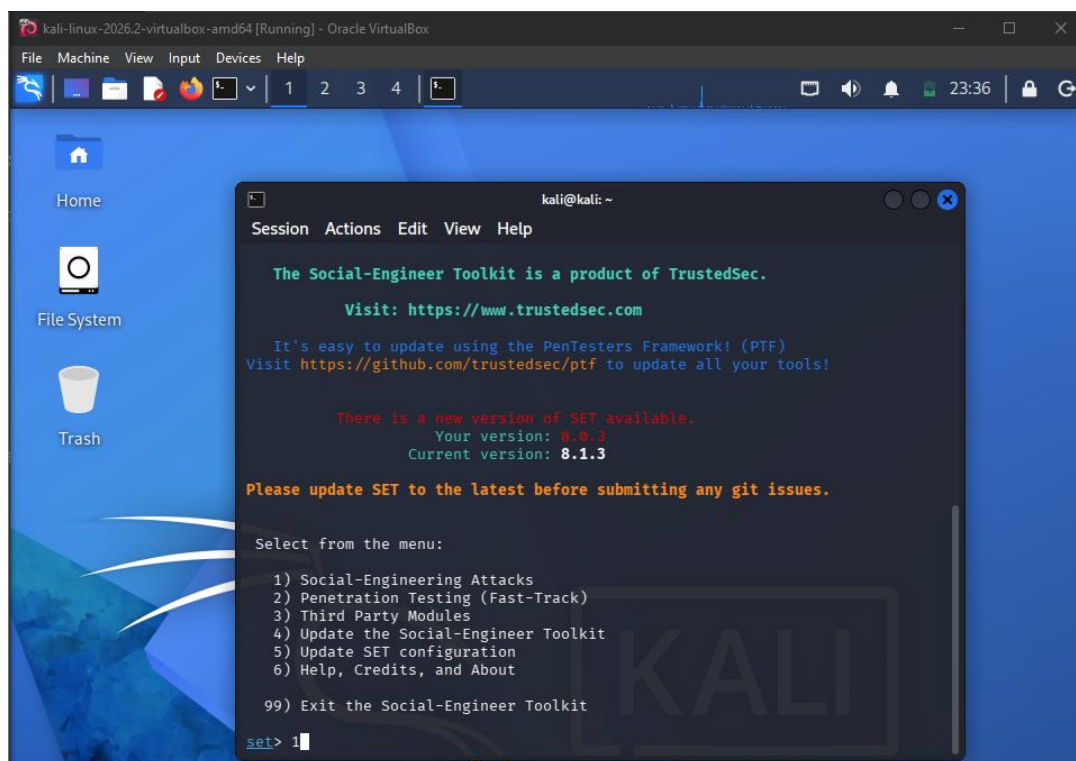
What is SETOOLKIT?

The **Social-Engineer Toolkit (SET)** is an open-source, Python-driven penetration testing framework specifically designed to simulate advanced social engineering attacks against the human element. Created by **David Kennedy (TrustedSec)**, **SET** is pre-installed in Kali Linux and serves as a standard tool for security professionals conducting authorized social engineering assessments. The toolkit heavily relies on the Metasploit Framework for payload generation and delivery.

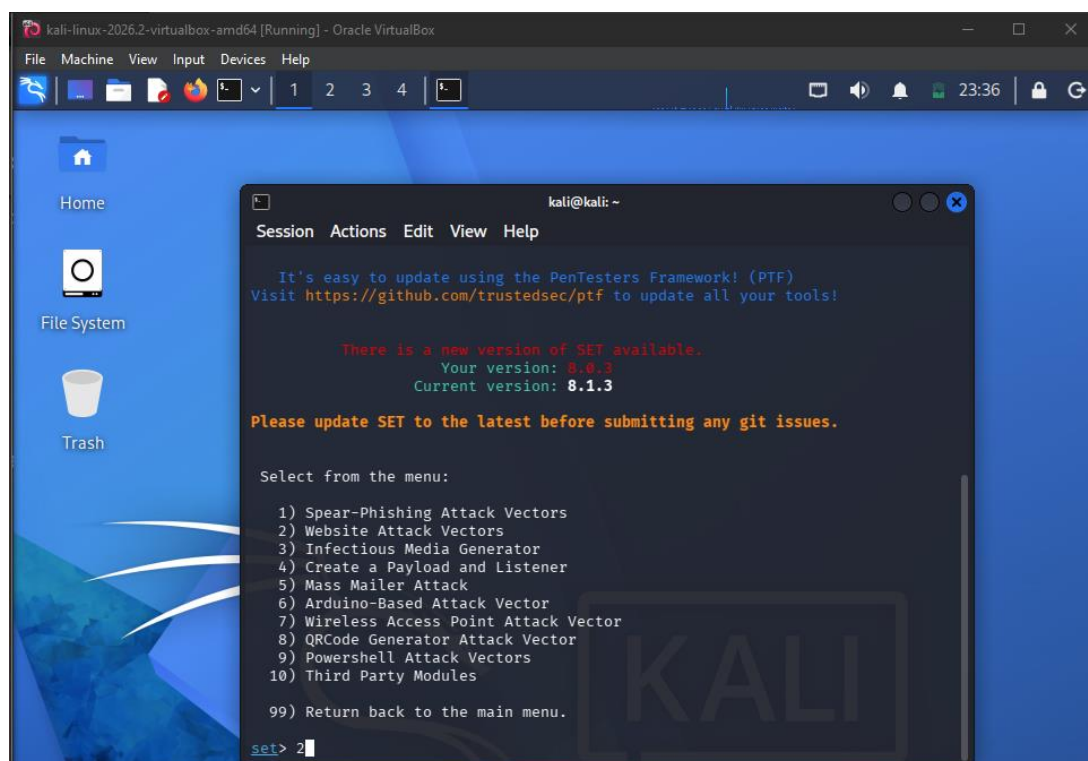


Objectives:

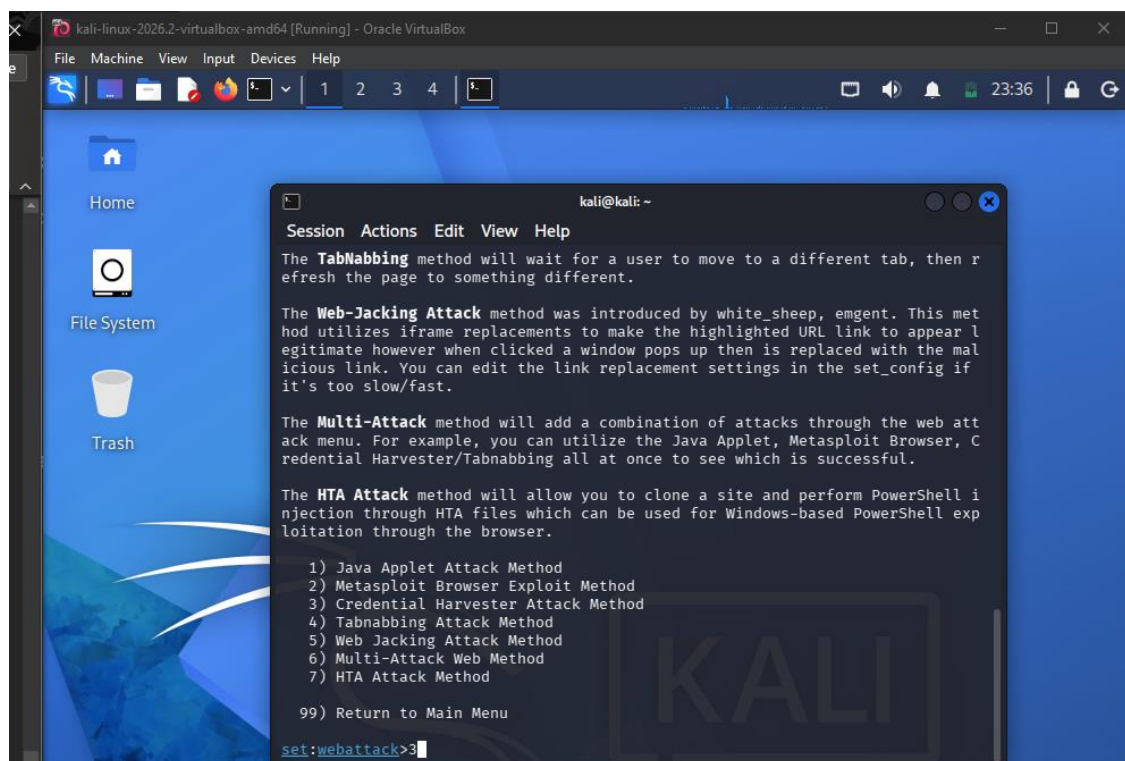
- **Account takeover:** Unauthorized access to victim accounts
- **Data breach:** Access to sensitive organizational or personal data
- **Lateral movement:** Using compromised credentials to access additional systems
- **Financial fraud:** Accessing financial accounts



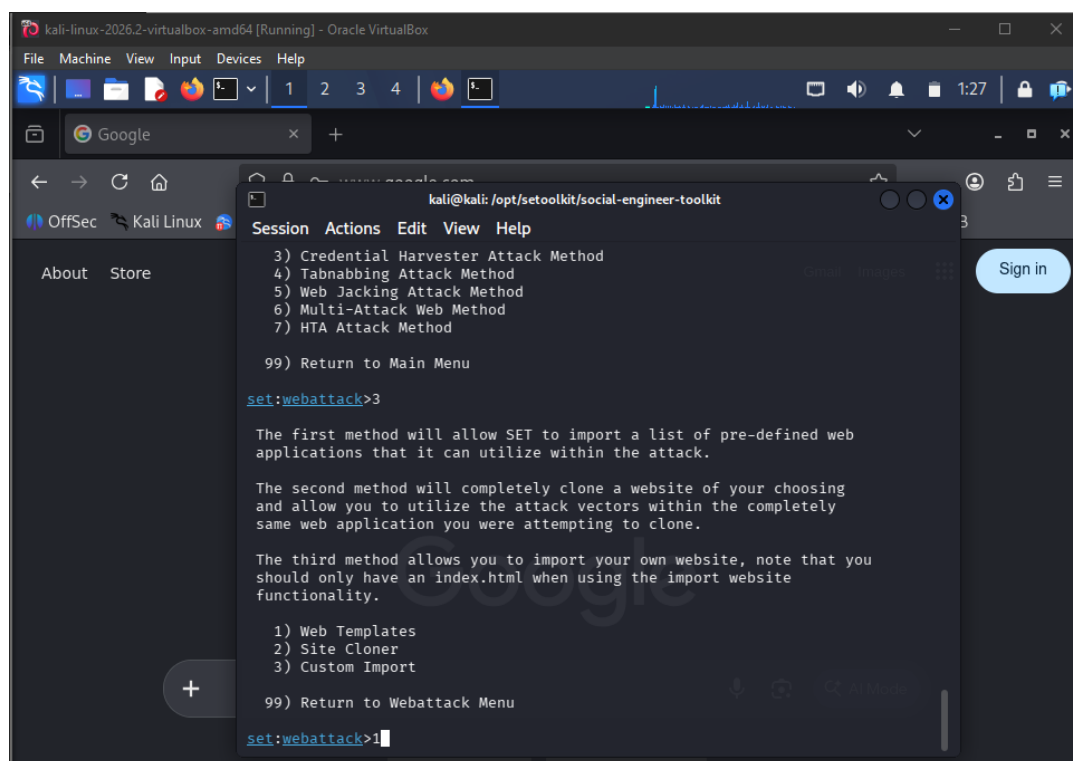
Kali Linux runs the Social-Engineer Toolkit for security testing.



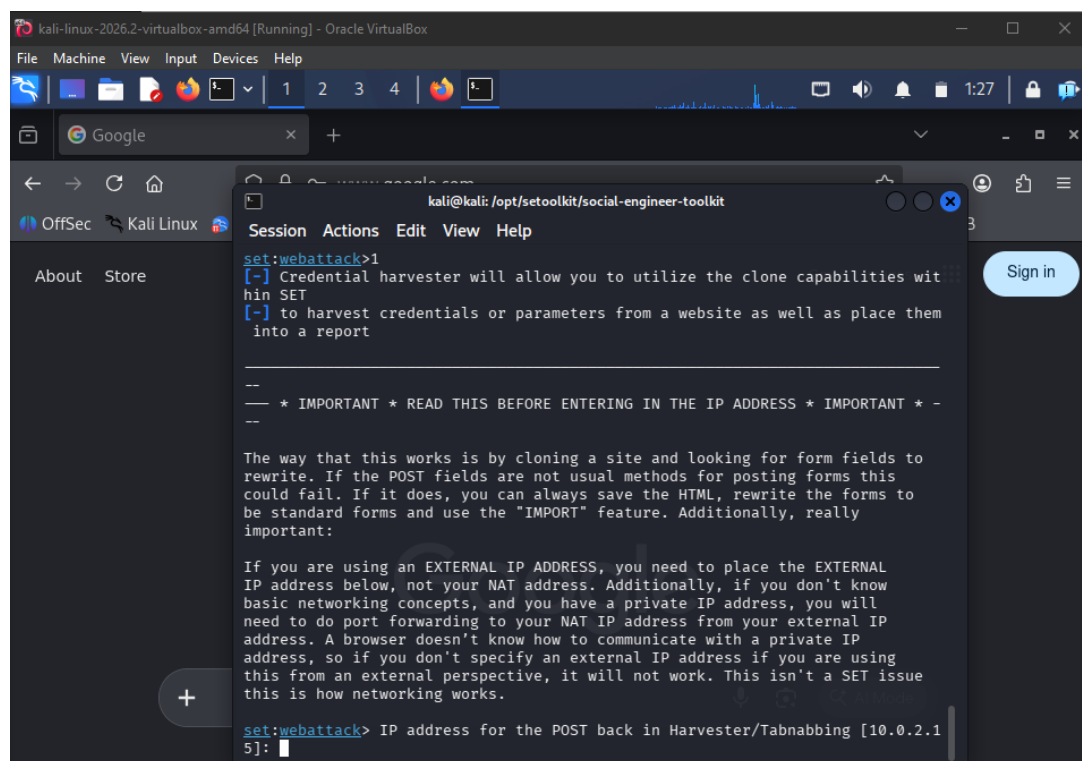
SET displays various social-engineering attack vectors for security testing.



SET displays web-based attack methods, including tabnabbing and credential harvesting.



SET launches a web attack method, offering templates, cloning, and custom imports.



```
kali@kali: /opt/setoolkit/social-engineer-toolkit
Session Actions Edit View Help
set:webattack>1
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

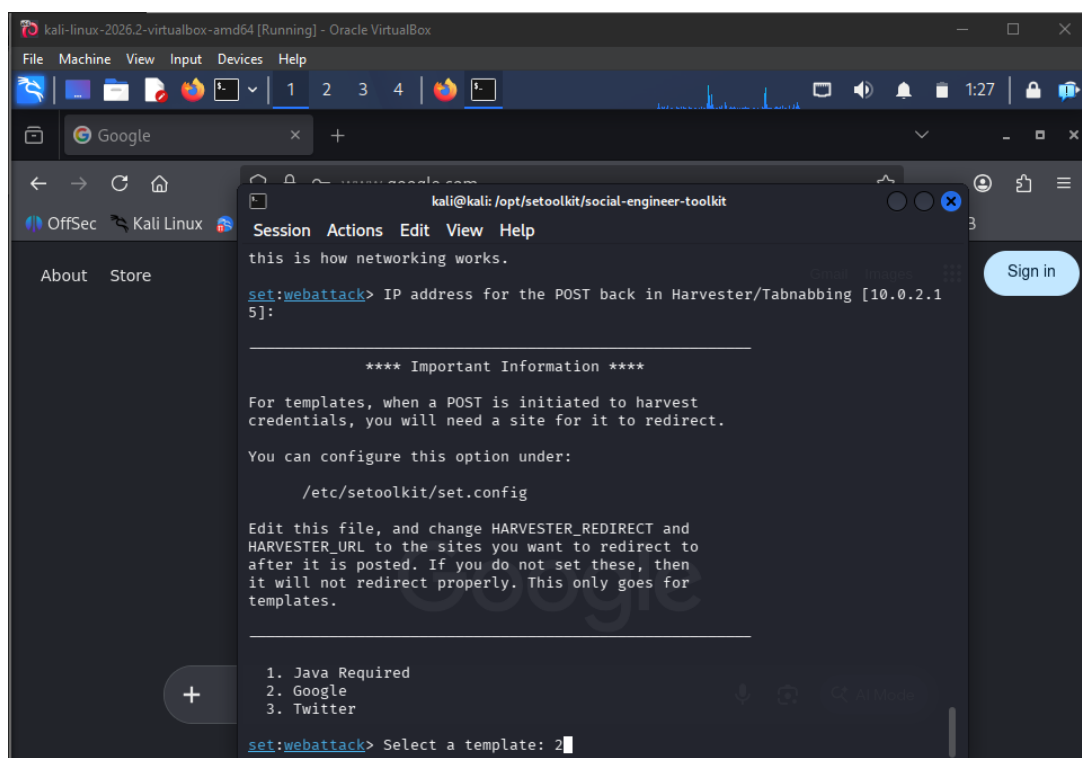
--
-- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * --
--

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
```

SET configures a credential-harvesting template and prepares its POST-back settings.



```
kali@kali: /opt/setoolkit/social-engineer-toolkit
Session Actions Edit View Help
this is how networking works.
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:

**** Important Information ****

For templates, when a POST is initiated to harvest credentials, you will need a site for it to redirect.

You can configure this option under:

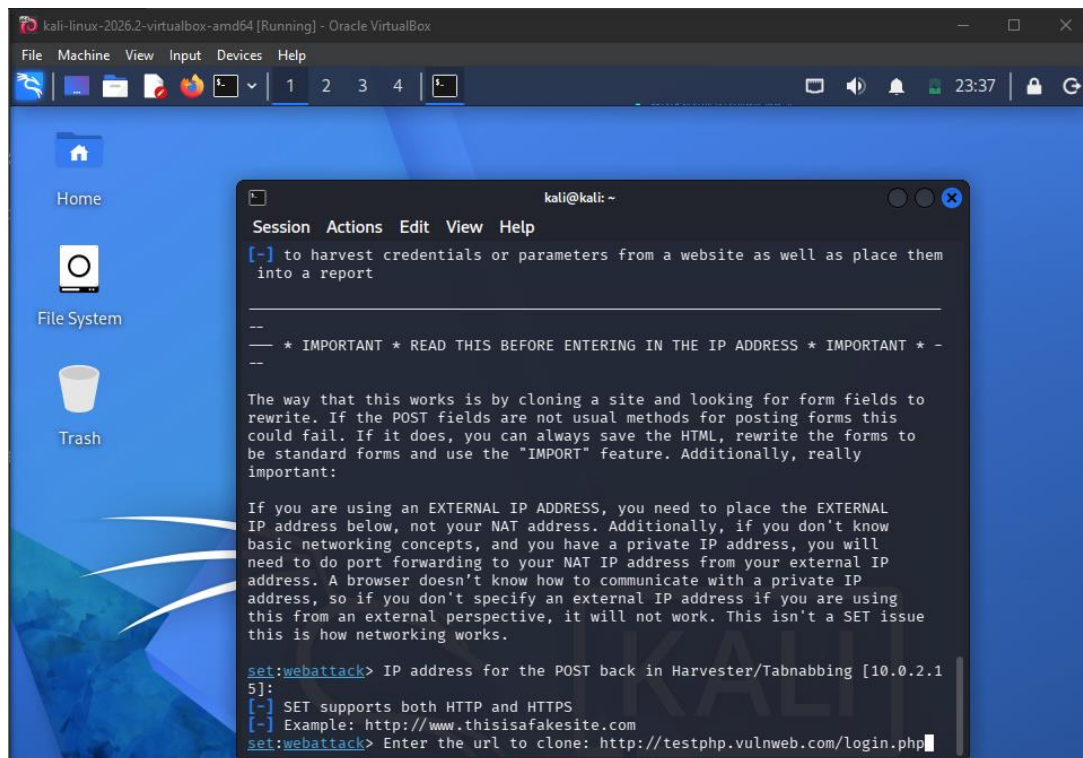
/etc/setoolkit/set.config

Edit this file, and change HARVESTER_REDIRECT and HARVESTER_URL to the sites you want to redirect to after it is posted. If you do not set these, then it will not redirect properly. This only goes for templates.

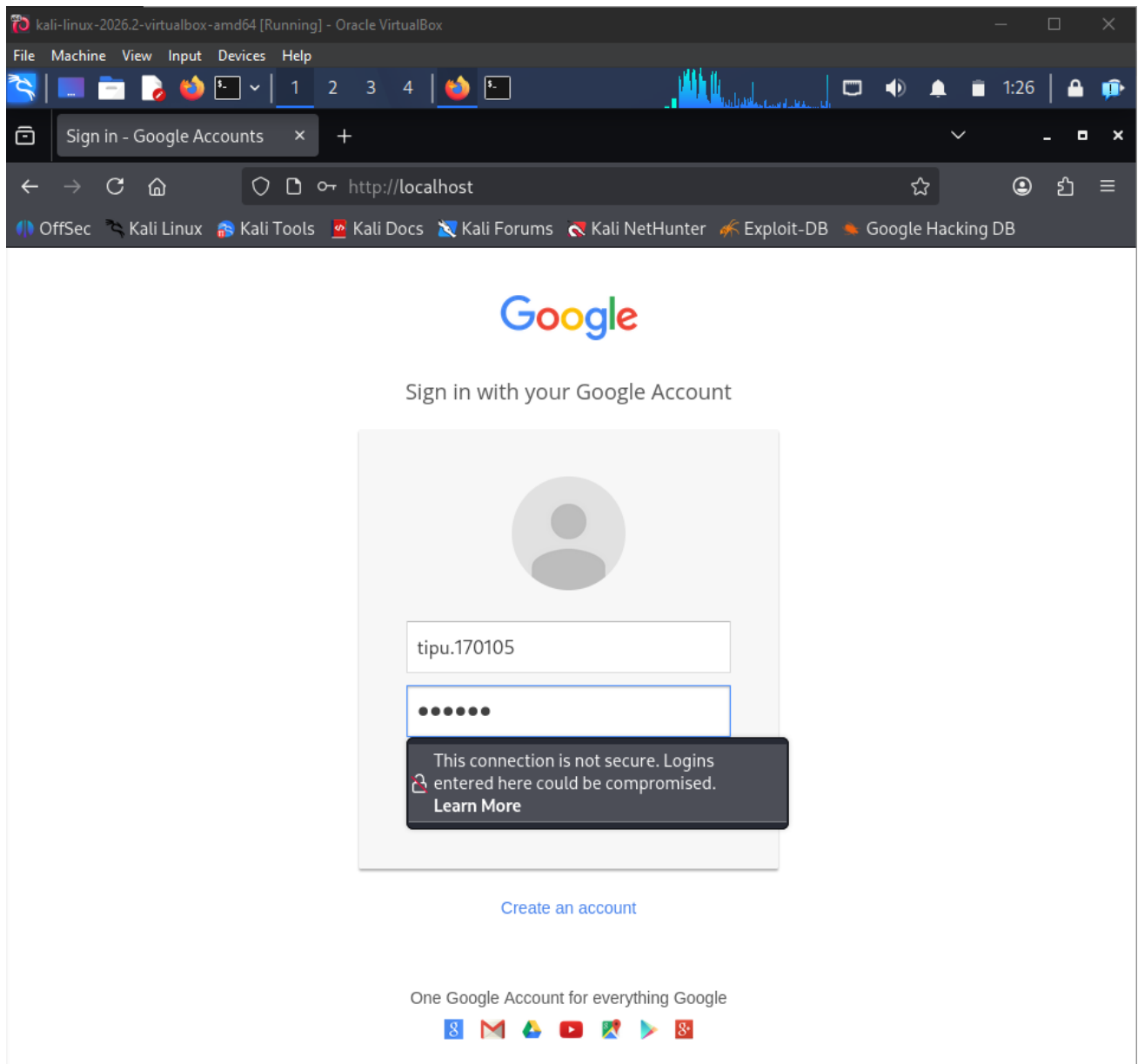
1. Java Required
2. Google
3. Twitter

set:webattack> Select a template: 2
```

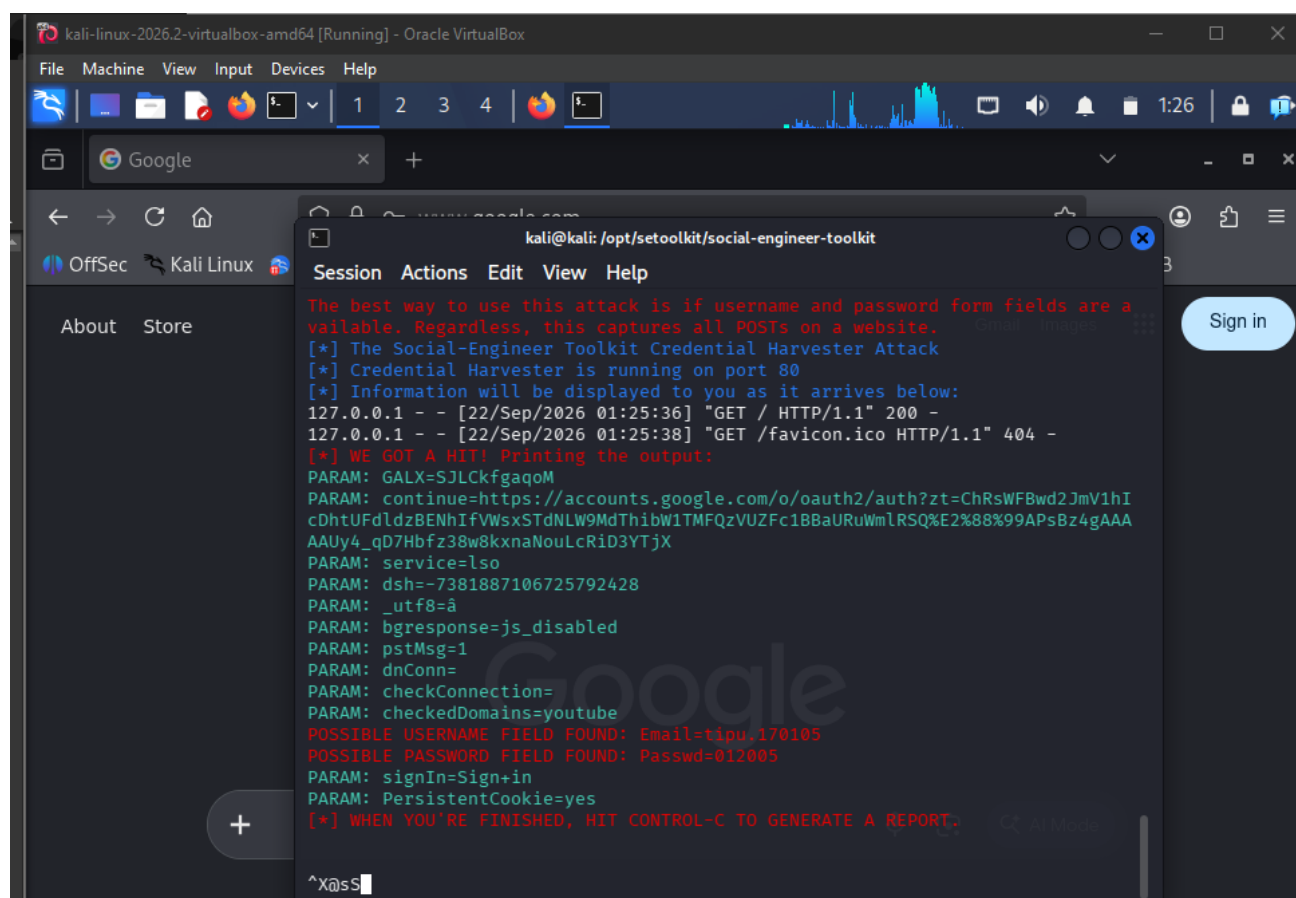
SET Toolkit cloning Google login page for credential harvesting attack.



SET prompts for IP address and target URL to clone the login page.



Cloned Google login page on localhost, warning of insecure connection.



SET successfully captures victim's Google username and password in terminal.

Conclusion

Successfully demonstrated how the Social-Engineer Toolkit (SET) can be used to perform a credential harvesting attack by cloning a legitimate Google login page and capturing user credentials, highlighting how easily attackers can exploit human trust to bypass technical security controls. The exercise underscores the critical importance of security awareness training, Multi-Factor Authentication (MFA), and URL verification as essential defenses against phishing and social engineering threats.